

Cloud Security — Tier 1

Comprehensive Master Study Notes & Accenture Technical Assessment MCQs

CORE CYBERSECURITY & CLOUD ARCHITECTURE

1. What is Cloud Security? ★★★★★

DEFINITION

Cloud Security is the set of policies, technologies, controls, and practices used to protect cloud-based data, applications, identities, networks, and infrastructure from unauthorized access, attacks, data loss, and other threats.

In simple words:

Cloud Security = Protecting resources and data stored, processed, or accessed through the cloud.

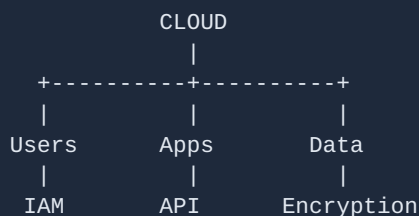
Examples of cloud resources:

- Virtual machines (Compute Engine, EC2, Azure VMs)
- Databases (Cloud SQL, DynamoDB, RDS)
- Cloud storage (S3 Buckets, Cloud Storage, Blob Storage)
- Applications & Serverless Functions
- APIs & Microservices
- User accounts & Service Principals
- Networks (VPCs, Subnets, Gateways)

Google Cloud describes cloud security as a combination of policies, practices, controls, and technologies used to protect cloud environments.

2. Why Do We Need Cloud Security?

Suppose a company stores customer data in the cloud:



Without security:

```

Attacker
|
↓
Cloud
|
+---- Steal data
+---- Modify data
+---- Delete data
+---- Stop application

```

Cloud security attempts to prevent these problems.

Main goals:

- Prevent unauthorized access
- Protect sensitive data
- Prevent data modification
- Maintain service availability
- Detect attacks
- Recover from incidents

3. Cloud Security vs Traditional Security

Traditional Data Center:

The organization usually controls the entire stack from bottom to top:

```
Physical Server → Network → Operating System → Application → Data
```

Cloud:

Responsibilities are divided dynamically between provider and customer:

```

Cloud Provider → Physical Infrastructure → Virtualization → Cloud Services
                                                         ↓
Customer          → Application + Data + Access

```

This leads to one of the most important Cloud Security concepts: **Shared Responsibility Model** (covered separately in detail).

4. CIA Triad ★★★★★

The **CIA Triad** is one of the most fundamental concepts in cybersecurity. CIA stands for:

- **C** → **Confidentiality** (Think: *Who can SEE?*)
- **I** → **Integrity** (Think: *Who can CHANGE?*)
- **A** → **Availability** (Think: *Can I USE it?*)

5. Confidentiality

DEFINITION

Confidentiality ensures that information is accessible only to authorized users or systems.

Example: A company's employee salary database should only be accessible to authorized HR personnel.

HR Employee → Salary Database → Access Granted ✓
Normal Employee → Salary Database → Access Denied ✗

Security mechanisms:

- Authentication & Multi-Factor Authentication (MFA)
- Authorization & Access Control Lists (ACLs)
- Identity and Access Management (IAM)
- Data Encryption (at rest & in transit)

ACCENTURE TRAP

If the question says: **"Prevent unauthorized access to data"** or **"Prevent unauthorized viewing"** → Think: **Confidentiality**

6. Integrity

DEFINITION

Integrity ensures that data remains accurate, complete, and protected from unauthorized modification.

Example:

Original: Account Balance = ₹50,000
Attacker changes it: Account Balance = ₹5,00,000

Result: The data has been modified without authorization → Integrity has been violated!

Security mechanisms:

- Cryptographic Hashing (SHA-256, MD5)
- Digital signatures
- Granular access control
- Checksums & HMAC
- Audit logs & File Integrity Monitoring (FIM)

ACCENTURE TRAP

If the question says: **"Prevent unauthorized modification of data"** or **"Ensure data accuracy"** → Think: **Integrity**

7. Availability

DEFINITION

Availability ensures that authorized users can access systems and data whenever required.

Example: An online banking application should always be accessible to customers.

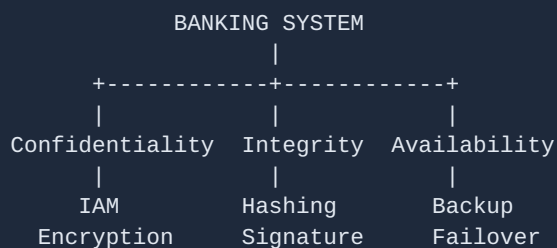
Normal: Customer → Banking Application → Available ✓

DDoS Attack: Millions of bot requests → Server → Overloaded ✗ → Service unavailable

Security mechanisms:

- Load balancing & Auto-scaling
- Redundancy & High Availability (HA)
- Automated backups & Disaster Recovery (DR)
- DDoS protection (Cloud Armor, AWS Shield)
- Automatic failover mechanisms

8. CIA Triad Example: Online Banking



- **Confidentiality:** Only the verified account owner can view account balances and statements.
- **Integrity:** The account balance and transaction records cannot be changed illegally.
- **Availability:** The banking application remains accessible 24/7 during peak traffic.

9. Important CIA Diagnostic Questions

- **Question:** A hacker reads a user's private medical records. Which CIA property is violated?
Answer: Confidentiality (Unauthorized viewing/reading)
- **Question:** A hacker modifies a patient's medical record.
Answer: Integrity (Unauthorized modification/tampering)
- **Question:** A hacker makes a hospital application unavailable.
Answer: Availability (Denial of service/access)

10. Cloud Security Controls

A **security control** is a technical, administrative, or physical safeguard used to reduce risk.

Threat / Vulnerability	Applied Security Control
Unauthorized access	Identity & Access Management (IAM)
Stolen password	Multi-Factor Authentication (MFA)
Data theft / sniffing	End-to-End Encryption (AES-256, TLS)
Unauthorized modification	Integrity checks, Hashing, Signatures
Malicious network traffic	Next-Gen Cloud Firewall / WAF
DDoS floods	DDoS protection & Rate Limiting
Data loss / corruption	Automated Redundant Backups
Suspicious activity / intrusion	Continuous Monitoring & SIEM
Excessive permissions	Principle of Least Privilege (PoLP)

Threat → Security Control → Risk Reduction

11. Preventive vs Detective vs Corrective Controls

This taxonomy is heavily tested in technical placement assessments and interviews.

A. Preventive Control (Stop before it happens)

Attempts to stop an attack or security incident before it occurs.

- **Examples:** Firewall, MFA, IAM policies, Encryption, Access control lists.

Attacker → Firewall →  Blocked

B. Detective Control (Detect during/after activity)

Attempts to identify and log an attack, policy violation, or suspicious behavior.

- **Examples:** Continuous Monitoring, IDS (Intrusion Detection Systems), Security audit logs, SIEM, Audit trails.

Attacker → System → Logs / IDS →  Alert

C. Corrective Control (Recover after damage)

Attempts to recover, repair, or restore systems and data back to normal after an incident.

- **Examples:** Backup restoration, Disaster recovery plans, Automated rollback, Incident response runbooks.

Attack → Damage → Backup & Recovery Plan → System Restored 

EASY MEMORY TRICK
Preventive → *Stop* | **Detective** → *Detect* | **Corrective** → *Recover*

12. Threat vs Vulnerability vs Risk

These terms are often confused in recruitment tests:

- **Threat:** Something or someone capable of causing harm. (e.g., *Hacker, Malware, DDoS botnet, Insider threat*)
- **Vulnerability:** A security weakness or flaw that can be exploited. (e.g., *Weak password, Unpatched OS, Public S3 bucket, Outdated library*)
- **Risk:** The potential loss or damage resulting from a threat exploiting a vulnerability. (e.g., *Risk of financial fraud, Data breach, Reputational loss*)

Weak password (Vulnerability) + Attacker (Threat) → Account compromise → Data theft (Risk)

Formula: Risk = Threat × Vulnerability × Impact

13. Cloud Misconfiguration ★★★★★

A cloud service provider can provide secure infrastructure, but if the customer configures settings incorrectly, vulnerabilities arise.

Cloud Storage → Public Access = ON ❌ → Sensitive files exposed to internet

The problem is not that the cloud provider was breached; the problem is incorrect customer configuration.

Common examples:

- Publicly open storage buckets (AWS S3, Google Cloud Storage)
- Open database ports directly exposed to 0.0.0.0/0
- Excessive IAM wildcard permissions (*)
- Hardcoded API keys pushed to public code repositories
- Disabled audit logging & monitoring
- Permissive security group rules

14. Cloud Account Security & Defense in Depth

Weak security: Username: admin | Password: password123 → Highly Dangerous!

Strong Security Architecture:

Username + Strong Password + MFA + Least Privilege + Continuous Monitoring

15. Defense in Depth ★★★★★

Defense in Depth means implementing multiple overlapping layers of security controls so that if one fails, subsequent layers continue to protect the system.

Internet → WAF → Firewall → Authentication → Authorization → App → Database → Encryption → Monitoring

Fail-Safe Example: If an attacker steals a user password:

Password stolen → Secondary Factor (MFA) → ❌ Access Blocked!

16. Important Cloud Security Principles

- **Principle 1 — Least Privilege:** Grant identities only the minimal permissions required for their tasks.
- **Principle 2 — Defense in Depth:** Deploy layered defenses across identity, network, compute, and data.
- **Principle 3 — Secure by Default:** Resources should default to highest protection (e.g., storage buckets closed by default).
- **Principle 4 — Continuous Monitoring:** Continuously monitor telemetry, logs, and behavior.
- **Principle 5 — Assume Breach:** Architect systems under the premise that attackers will breach perimeters (foundation of Zero Trust).

Cloud Security Tier 1 — Accenture MCQs (with Immediate Solutions)

Q1. What is the primary objective of Cloud Security?

- A. Increase cloud storage capacity
- B. Protect cloud resources, data, applications, and identities
- C. Reduce internet bandwidth
- D. Increase CPU performance

Answer: B ✓

Explanation:

- A ✗ — Storage capacity is a scalability concern, not security.
- B ✓ — Cloud security protects data, applications, identities, networks, and infrastructure.
- C ✗ — Bandwidth optimization is a performance/networking concern.
- D ✗ — CPU performance is unrelated to the primary purpose of security.

Interview point: Cloud Security protects cloud resources against unauthorized access, attacks, data loss, and other threats.

Q2. Which component of the CIA Triad ensures that only authorized users can access information?

- A. Integrity
- B. Availability
- C. Confidentiality
- D. Authentication

Answer: C ✓

Explanation:

- A ✗ Integrity → Protects data from unauthorized modification.
- B ✗ Availability → Ensures resources are accessible when needed.
- C ✓ Confidentiality → Prevents unauthorized access/disclosure.
- D ✗ Authentication → Verifies identity; it is a security mechanism, not a CIA component.

Remember: Confidentiality → Who can SEE the data?

Q3. A hacker modifies a customer's bank balance without authorization. Which security property has been violated?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Authentication

Answer: B ✓

Explanation:

- A ✗ — No unauthorized viewing is specified.
- B ✓ — Data was modified without authorization.
- C ✗ — The system is still available.
- D ✗ — Authentication concerns identity verification.

Rule: Integrity = Data should not be changed improperly.

Q4. A DDoS attack causes an online banking application to become unavailable. Which CIA property is primarily affected?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Authorization

Answer: C ✓

Explanation:

- A ✗ — No data disclosure is necessarily involved.
- B ✗ — No data modification is necessarily involved.
- C ✓ — The service is unavailable.
- D ✗ — Authorization controls access permissions.

Rule: DDoS → Targets Availability.

Q5. Which of the following is a vulnerability?

- A. Hacker
- B. Malware
- C. Weak password
- D. DDoS attacker

Answer: C ✓

Explanation:

- A ✗ — Hacker is a threat actor.
- B ✗ — Malware is a threat/attack mechanism.
- C ✓ — A weak password is a weakness that can be exploited.
- D ✗ — An attacker is a threat actor.

Remember: Vulnerability = Internal Weakness.

Q6. Which of the following is an example of a threat?

- A. Weak password
- B. Unpatched server
- C. Misconfigured storage bucket
- D. Hacker

Answer: D ✓

Explanation:

- A ✗ — Weak password is a vulnerability.
- B ✗ — Unpatched server is a vulnerability.
- C ✗ — Misconfiguration is a vulnerability.
- D ✓ — Hacker is a threat actor capable of causing harm.

Q7. A cloud administrator gives a developer only the permissions required to perform their assigned task. Which principle is being applied?

- A. Defense in Depth
- B. Least Privilege
- C. Availability
- D. Redundancy

Answer: B ✓

Explanation:

- A ✗ — Defense in depth means multiple security layers.
- B ✓ — Least privilege gives only minimum necessary permissions.
- C ✗ — Availability concerns accessibility.
- D ✗ — Redundancy means having additional resources for reliability.

Rule: Least Privilege = Minimum required permissions.

Q8. Which security approach uses multiple layers of protection?

- A. Least Privilege
- B. Defense in Depth
- C. Authentication
- D. Hashing

Answer: B ✓

Explanation:

- A ✗ — Controls permissions.
- B ✓ — Uses multiple layered security mechanisms (WAF → Firewall → MFA → IAM → Encryption → Monitoring).
- C ✗ — Verifies identity.
- D ✗ — Converts data into a fixed-length hash string.

Q9. Which is an example of a preventive security control?

- A. Security log analysis
- B. Firewall
- C. Incident report
- D. Backup restoration

Answer: B ✓

Explanation:

- A ✗ — Detective control.
- B ✓ — Firewall prevents unauthorized incoming/outgoing traffic.
- C ✗ — Incident reporting happens during/after detection.
- D ✗ — Backup restoration is a corrective/recovery control.

Rule: Preventive → Stop before breach.

Q10. Which is an example of a detective security control?

- A. Firewall
- B. MFA
- C. Security monitoring
- D. Encryption

Answer: C ✓

Explanation:

- A ✗ — Primarily preventive.
- B ✗ — Primarily preventive.
- C ✓ — Monitoring actively detects suspicious activity in real time.
- D ✗ — Protects confidentiality (preventive).

Rule: Detective → Detect during/after.

Q11. Which is an example of a corrective control?

- A. Firewall
- B. MFA
- C. Backup restoration
- D. Encryption

Answer: C ✓

Explanation:

- A ✗ — Preventive.
- B ✗ — Preventive.
- C ✓ — Restores damaged systems/data back to operational status.
- D ✗ — Preventive cryptographic mechanism.

Rule: Corrective → Recover/Fix.

Q12. A company accidentally configures its cloud storage so that anyone on the internet can access sensitive files. What is this primarily an example of?

- A. DDoS
- B. Cloud misconfiguration
- C. Hash collision
- D. Authentication failure

Answer: B ✓

Explanation:

- A ✗ — DDoS targets service availability.
- B ✓ — Incorrect customer configuration exposed public permissions.
- C ✗ — Hash collision is a mathematical cryptography issue.
- D ✗ — The issue is permissions/access control setting error.

Key takeaway: Cloud misconfiguration is the #1 cause of cloud data breaches.

Q13. Which security property is primarily protected by encryption?

- A. Confidentiality
- B. Availability
- C. Scalability
- D. Performance

Answer: A ✓

Explanation:

- A ✓ — Encryption transforms plaintext into ciphertext so unauthorized parties cannot read it (protects Confidentiality).
- B ✗ — Availability is maintained by redundancy and backups.
- C ✗ — Scalability is handled by cloud auto-scaling.
- D ✗ — Encryption can introduce computational overhead, not performance gains.

Q14. Which statement correctly describes encryption?

- A. Encryption is always irreversible
- B. Encryption converts plaintext into ciphertext
- C. Encryption is only used for passwords
- D. Encryption detects network attacks

Answer: B ✓

Explanation:

- A ✗ — Encryption is reversible using the correct decryption key.
- B ✓ — Plaintext + Key → Encryption → Ciphertext.
- C ✗ — Encryption protects databases, files, network traffic, etc.
- D ✗ — Attack detection is an IDS/SIEM function.

Q15. Which statement about hashing is correct?

- A. Hashing is normally designed as a one-way operation
- B. Hashing always uses a public and private key
- C. Hashing is the same as encryption
- D. Hashing is primarily used to increase storage capacity

Answer: A ✓

Explanation:

- A ✓ — Cryptographic hashing is one-way (infeasible to reverse).
- B ✗ — Key pairs belong to asymmetric encryption, not basic hashing.
- C ✗ — Encryption is two-way (reversible); Hashing is one-way (irreversible).
- D ✗ — Hashing verifies data integrity.

Q16. Which mechanism is most directly used to verify the identity of a user?

- A. Authorization
- B. Authentication
- C. Encryption
- D. Availability

Answer: B ✓

Explanation:

- A ✗ — Authorization determines *"WHAT permissions do you have?"*.
- B ✓ — Authentication determines *"WHO are you?"*.
- C ✗ — Protects data confidentiality.
- D ✗ — Ensures resource accessibility.

Q17. A user successfully logs in and is then allowed to read only a particular database. Which concepts are involved?

- A. Authentication and Authorization
- B. Encryption and Hashing
- C. Availability and Integrity
- D. Backup and Recovery

Answer: A ✓

Explanation:

- Logging in = **Authentication** (verifying user credentials).
- Restricting access to read-only on specific database = **Authorization** (verifying access permissions).

Q18. Which of the following is an example of Multi-Factor Authentication?

- A. Password only
- B. Username only
- C. Password + OTP
- D. PIN only

Answer: C ✓

Explanation:

- A, B, D ✗ — Single factor (Something you know).
- C ✓ — Combines two distinct authentication factors: Password (Something you know) + OTP (Something you have).

Q19. Which statement BEST describes cloud security?

- A. The cloud provider is responsible for everything
- B. The customer is responsible for everything
- C. Security responsibilities are shared depending on the cloud service
- D. Cloud environments do not require security controls

Answer: C ✓

Explanation:

- Responsibilities are divided between provider and customer according to the service model (IaaS, PaaS, SaaS). This is the **Shared Responsibility Model**.

Q20. Which combination is CORRECT?

- A. Confidentiality → Data modification
- B. Integrity → Unauthorized access
- C. Availability → Service accessibility
- D. Authentication → Data recovery

Answer: C ✓

Explanation:

- A ✗ — Confidentiality protects against unauthorized disclosure/access.
- B ✗ — Integrity protects against unauthorized data modification.
- C ✓ — Availability ensures systems and data remain accessible when needed.
- D ✗ — Authentication is identity verification, not recovery.